

Практикум 2 (Защита веб-приложений на примере DVWA)

Антон Покидько
Иван Степанов

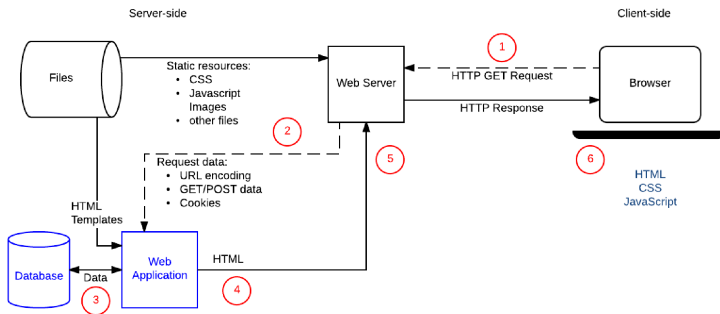
8 октября 2025 г.

- 1 Web-сервер
- 2 Web application firewall
- 3 DVWA
- 4 ModSecurity
- 5 Задание

Web-сервер

Что это такое?

Web-сервер — сервер, принимающий HTTP(S)-запросы от клиентов, обычно веб-браузеров, и выдающий им HTTP(S)-ответы, как правило, вместе с HTML-страницей, изображением, файлом, медиа-потокom или другими данными.



Web-сервер, предоставляя большие возможности, является "желаемой" целью для атаки злоумышленников из-за своей общедоступности и "распределенной природы".

Как следствие есть уязвимости и угрозы

- 1. Угрозы со стороны клиента
 - 2. Угрозы со стороны сервера
 - 3. Угроза одного пользователя другому
 - 4. Угроза от стороннего сервера
-
- 1. **Инъекции** - внедрение и исполнение кода на сервере
 - 2. **Brute Force** - Получение логина/пароля администратора

Web application firewall

Что это такое?

Файрвол веб-приложений - система безопасности, которая помогает защищать веб-приложения путем фильтрации, мониторинга и анализа трафика HTTP/HTTPS между веб-приложением и Интернетом.

Типы WAF:

- **Сетевой WAF:** обычно разворачивается на аппаратных устройствах и размещается на границе сети, обеспечивая высокоскоростную защиту.
- **Host-based WAF:** устанавливается на том же сервере, что и веб-приложение. Гибкие, но могут быть ресурсоемкими.
- **Облачные WAF:** предоставляются поставщиками облачных услуг.

DVWA

Что это такое?

Damn Vulnerable Web Application (DVWA) – это веб-приложение PHP / MySQL, которое **очень и очень уязвимо**.

Для чего оно нужно?

Основная цель DVWA – помочь веб-разработчикам лучше понять **процессы обеспечения безопасности веб-приложений** и помочь студентам и преподавателям узнать о безопасности веб-приложений в контролируемой среде.

Внимание!

DVWA очень и очень уязвим! Не загружайте его в общедоступную html-папку хостинг-провайдера или на любые серверы, обращенные к Интернету, поскольку они будут скомпрометированы. Рекомендуется установить данное приложение для тестирования на виртуальную машину или Kali Linux, В случае виртуальной машины мы можем предоставить приложению любое требуемое ему окружение без ущерба для других компонентов.

Так выглядит основное меню DVWA, слева атаки.

Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

CSP Bypass

JavaScript

DVWA Security

PHP Info

About

Logout

Welcome to Damn Vulnerable Web Application!

Damn Vulnerable Web Application (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goal is to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and to aid both students & teachers to learn about web application security in a controlled class room environment.

The aim of DVWA is to **practice some of the most common web vulnerabilities, with various levels of difficulty**, with a simple straightforward interface.

General Instructions

It is up to the user how they approach DVWA. Either by working through every module at a fixed level, or selecting any module and working up to reach the highest level they can before moving onto the next one. There is not a fixed object to complete a module, however users should feel that they have successfully exploited the system as best as they possible could by using that particular vulnerability.

Please note, there are **both documented and undocumented vulnerability** with this software. This is intentional. You are encouraged to try and discover as many issues as possible.

DVWA also includes a Web Application Firewall (WAF), PHPIDS, which can be enabled at any stage to further increase the difficulty. This will demonstrate how adding another layer of security may block certain malicious actions. Note, there are also various public methods at bypassing these protections (so this can be seen as an extension for more advanced users)

There is a help button at the bottom of each page, which allows you to view hints & tips for that vulnerability. There are also additional links for further background reading, which relates to that security issue.

WARNING!

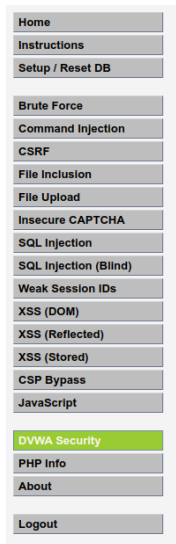
Damn Vulnerable Web Application is damn vulnerable! **Do not upload it to your hosting provider's public html folder or any Internet facing servers**, as they will be compromised. It is recommend using a virtual machine (such as [VirtualBox](#) or [VMware](#)), which is set to NAT networking mode. Inside a guest machine, you can downloading and install [XAMPP](#) for the web server and database.

Disclaimer

We do not take responsibility for the way in which any one uses this application (DVWA). We have made the purposes of the application clear and it should not be used maliciously. We have given warnings and taken measures to prevent users from installing DVWA on to live web servers. If your web server is compromised via an installation of DVWA it is not our responsibility it is the responsibility of the person/s who uploaded and installed it.

Какие уязвимости имеет DVWA:

- **Brute Force:** подбор пароля методом полного перебора.
- **Исполнение (внедрение) команд:** выполнение команд уровня операционной системы.
- **Межсайтовая подделка запроса (CSRF):** атака, при которой злоумышленник заставляет браузер жертвы выполнить нежелательный запрос к сайту, где жертва аутентифицирована.
- **Внедрение (инклюд) файлов:** позволяет «атакующему» присоединить удалённые/локальные файлы в веб-приложение.
- **Инъекция SQL:** позволяет «атакующему» внедрить SQL выражения в HTTP из поля ввода, DVWA включает слепое и основанное на ошибке SQL внедрение.
- **Межсайтовый скриптинг (XSS):** «атакующий» может внедрить свои скрипты в веб-приложение/базу данных. DVWA включает отражённую и хранимую XSS.

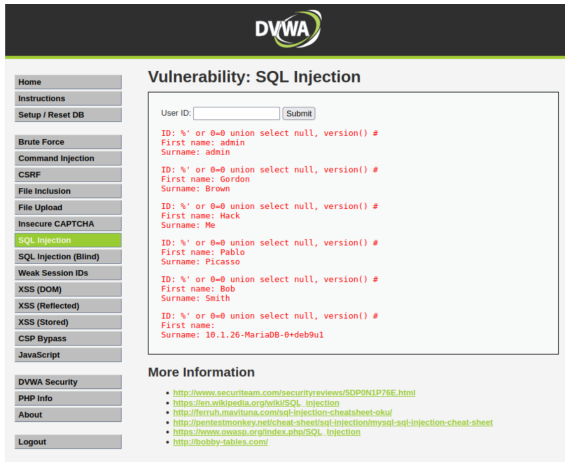


Какие уязвимости имеет DVWA:

- **Невозможный:** этот уровень должен быть безопасным от всех уязвимостей.
- **Высокий:** реализованы базовые меры защиты, как в реальных приложениях.
- **Средний:** этот уровень безопасности предназначен главным образом для того, чтобы дать пользователю пример плохих практик безопасности.
- **Низкий:** этот уровень безопасности совершенно уязвим и совсем не имеет защиты. Необходим для отработки базовых принципов защиты и уязвимостей.

Пример SQL-инъекции в DVWA

Введём в поле User ID: `1' OR '1'='1 'union select null, version()'`
Получим версию базы данных.



DVWA

Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
DVWA Security
PHP Info
About
Logout

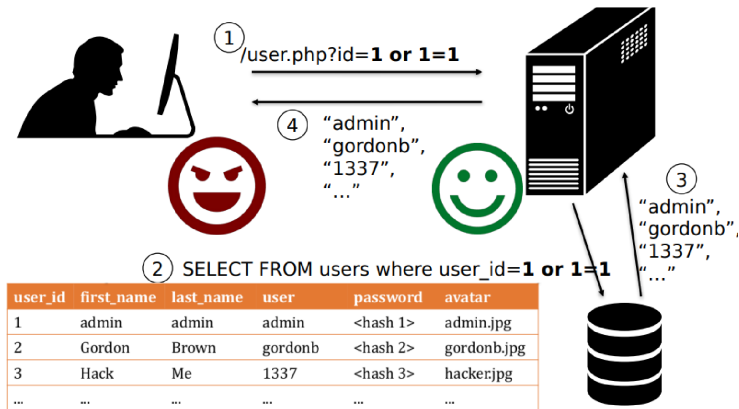
Vulnerability: SQL Injection

User ID: Submit

```
ID: %' or 0=0 union select null, version() #  
First name: admin  
Surname: admin  
  
ID: %' or 0=0 union select null, version() #  
First name: Gordon  
Surname: Brown  
  
ID: %' or 0=0 union select null, version() #  
First name: Hack  
Surname: Me  
  
ID: %' or 0=0 union select null, version() #  
First name: Pablo  
Surname: Picasso  
  
ID: %' or 0=0 union select null, version() #  
First name: Bob  
Surname: Smith  
  
ID: %' or 0=0 union select null, version() #  
First name:  
Surname: 10.1.26-MariaDB-0+deb9u1
```

More Information

- <http://www.securiteam.com/securityreviews/5DP0N1P76E.html>
- https://en.wikipedia.org/wiki/SQL_injection
- <http://ferruh.mavibuna.com/sql-injection-cheatsheet-oku/>
- <http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet>
- https://www.owasp.org/index.php/SQL_injection
- <http://bobby-tables.com/>



Пример SQL-инъекции в DVWA (cURL)

1.

Заходим в командную строку linux.

2.

Нам нужно ввести команду: `curl -v <URL атаки в DVWA в кавычках> -b "PHPSESSID=<YourCOOKIE>;security=low"`

3.

YourCOOKIE - это ваши куки на сайте DVWA. Каких их узнать?

4.

Если у вас Firefox, то заходим в другие инструменты -> инструменты веб-разработчика -> хранилище -> куки.

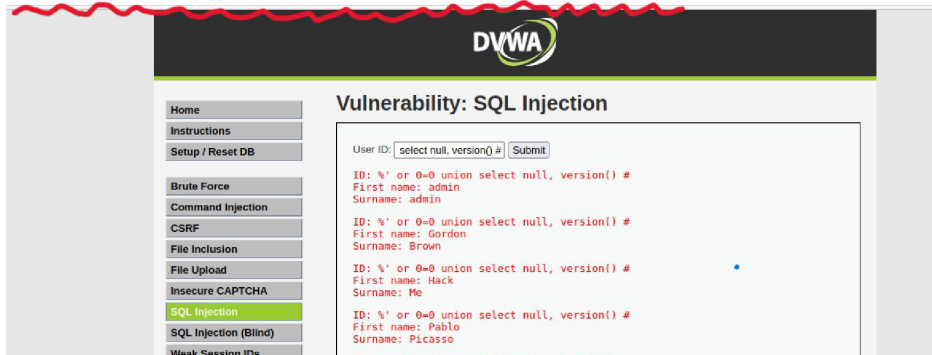
В других браузерах примерно похожий алгоритм.

URL атаки в DVWA

Теперь разберёмся как узнать URL атаки в DVWA.

Осуществляем SQL-инъекцию, видим следующую картинку. Нам понадобится то, что выделено красной волнистой линией.

`dvwa.rerand0m.ru/vulnerabilities/sqli/?id=%25'+or+0%3D0+union+select+null%2C+version()+%23&Submit=Submit#`



Если всё сделали правильно, то увидим:

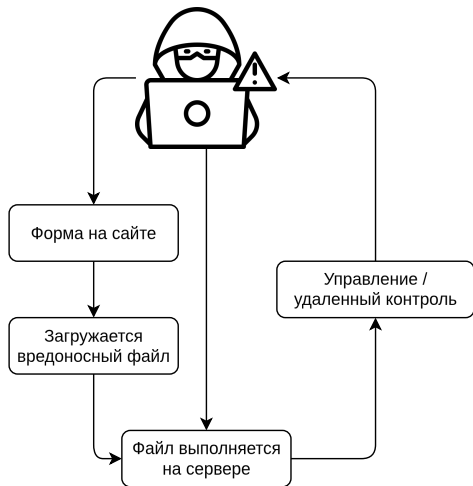
```
</form>
<pre>ID: '%' or 0=0 union select null, version() #<br />First name: admin<br />Surname: admin</pre><pre>ID: '%' or 0=0 union select null, version() #<br />First name: Gordon<br />Surname: B
town</pre><pre>ID: '%' or 0=0 union select null, version() #<br />First name: Hack<br />Surname: Me</pre><pre>ID: '%' or 0=0 union select null, version() #<br />First name: Pablo<br />Surname: Picasso</pre>
<pre>ID: '%' or 0=0 union select null, version() #<br />First name: Bob<br />Surname: Smith</pre><pre>ID: '%' or 0=0 union select null, version() #<br />First name: <br />Surname: 10.1.26-MariaDB-0+deb9u1
</pre>
```

Если всё сделали правильно, то в ответе увидим версию базы данных.

User-Agent

Кроме того, в curl мы можем указать конкретное значение User-Agent, **определённым ключом**.

Позволяет злоумышленнику загрузить или внедрить на сервер вредоносный скрипт (web shell) и получить удалённый доступ к системе.



Vulnerability: File Upload

Choose an image to upload:

backdoor.php

Index of /hackable/uploads

Name	Last modified	Size	Description
 Parent Directory		-	
 backdoor.php	2025-10-07 16:17	514	
 bd.php	2024-09-30 14:52	517	
 bd.txt	2025-10-07 12:59	0	
 dvwa_email.png	2018-10-12 17:44	667	

Apache/2.4.25 (Debian) Server at localhost Port 80

ModSecurity

- **WAF ModSecurity** – один из наиболее распространенных open-source межсетевых экранов веб-приложений, состоящий из двух основных частей: **движок** и **набор правил**.
- Де-факто стандартом является применение WAF ModSecurity с набором сигнатур обнаружения атак OWASP ModSecurity **Core Rule Set (CRS)**.
- Основная задача CRS – обеспечить защиту веб-приложений от широкого перечня атак, с минимумом ложных срабатываний.
- CRS обеспечивает защиту от большинства известных атак, включая SQL Injection, Cross Site Scripting, Local File Inclusion и др.

Версия	Язык	Совместимость	Тесты
ModSecurity 2	c++	с Apache	100% модульных тестов CRS
ModSecurity 3	c++	с Nginx	терпит неудачу в 2-4% тестов CRS
Coraza WAF	GO	с Caddy и Traefik	100% модульных тестов CRS

Таблица: Версии ModSecurity

Задание

Немного "душных" правил

Пример

- Меня зовут: Иванов Петр Сергеевич
- Мой вуз: МГУ, МФТИ, ВШЭ
- Моя группа: 999, М99-999х, мСП99

- Подстановки:

- <фамилияио> = ivanovps
- <группа> = 999|m99_999x|msp99
- <вуз> = msu|mpt|hse

- Тема письма с решением:

- *msu-999-p1_{1,2,3}*
- *mpt-m99_999x-p1_{1,2,3}*
- *hse-msp99-p1_{1,2,3}*

- Название архива:

- *ivanovps-999-p1_{1,2,3}.zip*
- *ivanovps-m99_999x-p1_{1,2,3}.zip*
- *ivanovps-msp99-p1_{1,2,3}.zip*

- Посылки с иным форматом будут **проигнорированы**

Дедлайн: 22 октября (23:59).

Если на посылку нет реакции более 3 рабочих дней, то письмо могло попасть в спам — свяжитесь с принимающим в ТГ.

- 1 Зайти в директорию лабораторной и запустить стенд
`$ docker compose up`
- 2 Переходим на `http://localhost/setup.php` и жмем **Create / Reset Database**
- 3 Открываем kali
`$ docker exec -it kali bash`
- 4 Зайти через бекдор с помощью weeveily по адресу
`http://localhost/hackable/uploads/bd.php`, пароль **123**
 - Документация weeveily: <https://github.com/epinna/weeveily3>
- 5 Используя команду `mysql` добавить пользователя. Поля `user`, `last_name`, `first_name` - имя которое используете для сдачи заданий. `password` - md5 хеш этого имени.

- 6 Авторизироваться на `http://localhost` и перейти в `http://localhost/vulnerabilities/sql/`. Вывести список пользователей используя SQL инъекцию
`1' OR '1'='1`
- 7 Заблокировать эту SQL инъекцию и возможность использовать бекдор написав правила для ModSecurity (Coraza WAF) в файле `traefik/dynamic_conf.yml` (изменения применяются автоматически, как только файл обновляется).
 - Сервер должен возвращать ошибку 403
 - Документация Coraza: <https://coraza.io/docs/seclang/operators/>

Задание

В качестве результата вам нужно будет прислать две отфильтрованные трассы (для успешной и заблокированной sql инъекции) и файл `dynamic_conf.yml`. Название трасс:

- Успешная и заблокированная инъекция: `<фамилияио>-sqli-access.pcap`
`<фамилияио>-sqli-block.pcap`
- Успешный и заблокированный web shell: `<фамилияио>-ws-access.pcap`
`<фамилияио>-ws-block.pcap`
- `dynamic_conf.yml`: `<фамилияио>-dynamic_conf.yml`

Указанные файлы необходимо отправить в архиве с именем `<фамилияио>-<группа>-p2.zip` и отправить на почту, указав в теме письма `<вуз>-<группа>- p2`.